

CYB-049 : Tests de conformité et audits techniques

Introduction Générale du Cours

La cybersécurité n'est pas un état que l'on atteint un jour pour ne plus jamais y revenir. C'est un processus continu d'évaluation, d'amélioration et de vérification. Les menaces évoluent, les systèmes d'information changent, les équipes tournent, les configurations dérivent. Sans mécanismes de contrôle réguliers, les mesures de sécurité déployées — aussi robustes soient-elles au moment de leur mise en place — se dégradent progressivement jusqu'à perdre leur efficacité, souvent sans que personne ne s'en aperçoive avant qu'un incident ne vienne révéler brutalement les lacunes accumulées.

Les tests de conformité et les audits techniques sont les instruments qui permettent à une organisation de maintenir une vision lucide et objective de son niveau réel de sécurité. Ils répondent à une question fondamentale : ce que nous pensons avoir mis en place est-il réellement en place, correctement configuré, et toujours efficace face aux menaces actuelles ? Cette question, simple en apparence, est en réalité l'une des plus difficiles à répondre honnêtement, tant la perception interne de la sécurité tend naturellement à surestimer le niveau réel de protection.

Ce cours explore les fondements, les méthodes et les outils des audits techniques de sécurité : les référentiels qui les structurent (ISO 27001, CIS Controls, PCI-DSS, NIS2), les différents types de contrôles et leurs objectifs spécifiques, la méthodologie rigoureuse de réalisation et de documentation des écarts, les outils d'analyse et de scan qui automatisent les vérifications techniques, et la construction de plans d'action correctifs exploitables. Il aborde également la dimension organisationnelle de l'audit — comment planifier un programme d'audit annuel cohérent, comment piloter la correction des écarts dans le temps, comment communiquer les résultats à la direction de manière pertinente.

Objectifs Pédagogiques du Module

À l'issue de ce cours, l'apprenant doit être capable de :

1. Maîtrise Conceptuelle et Réglementaire

- Comprendre le rôle et les enjeux des audits de sécurité dans une démarche de cyberdéfense continue.
- Identifier les principaux référentiels applicables (ISO 27001, CIS Controls, NIS2, PCI-DSS, DORA) et leurs exigences en matière de contrôles réguliers.
- Distinguer les différents types d'audits (conformité, configuration, vulnérabilités, intrusion, droits d'accès) et leurs objectifs respectifs.

2. Compétences Techniques et Opérationnelles

- Appliquer la méthodologie d'un audit technique en six phases, de la préparation à la clôture du plan d'action.
- Réaliser un audit de configuration en utilisant les benchmarks CIS et des outils automatisés (CIS-CAT, scripts PowerShell et Bash).
- Conduire un scan de vulnérabilités avec Nessus ou OpenVAS et interpréter les résultats selon le score CVSS.
- Auditer les droits d'accès d'un Active Directory et identifier les comptes et groupes présentant des risques de sécurité.

3. Expertise en Documentation et Reporting

- Documenter les écarts identifiés de manière structurée, factuelle et référencée au référentiel applicable.
- Construire un plan d'action correctif (PAC) priorisé, avec responsables désignés, délais définis et critères de clôture vérifiables.
- Rédiger un rapport d'audit adapté aux audiences techniques et direction, synthétisant les constats et les risques associés.

4. Pilotage et Amélioration Continue

- Construire et piloter un programme d'audit annuel couvrant les principales dimensions de la sécurité du SI.
- Mettre en place des indicateurs de suivi de la conformité et de l'avancement du plan d'action.
- Comprendre les mécanismes de certification et d'audit externe (ISO 27001, PCI-DSS QSA, DORA TLPT).

Chapitre 1 : Fondements des Audits de Sécurité

1. Définition et Finalité d'un Audit de Sécurité

Un audit de sécurité est un processus d'évaluation systématique et indépendant visant à mesurer le niveau réel de sécurité d'un système d'information par rapport à un référentiel défini. Il se distingue d'une simple vérification ponctuelle par sa rigueur méthodologique, sa traçabilité documentaire et son caractère contradictoire — les constats sont présentés à l'entité auditée pour validation factuelle avant publication. L'audit produit une image objective de l'état de sécurité à un instant donné, identifie les écarts par rapport aux exigences applicables, et formule des recommandations concrètes pour les corriger.

La finalité d'un audit de sécurité est triple. La finalité de contrôle vise à vérifier que les mesures de sécurité décidées sont effectivement mises en place et fonctionnent comme prévu — combler l'écart entre ce que l'on pense faire et ce que l'on fait réellement. La finalité d'amélioration fournit à l'organisation une base factuelle pour prioriser ses investissements en sécurité, en ciblant les contrôles les plus défaillants et les risques les plus élevés. La finalité de conformité démontre aux parties prenantes externes — clients, partenaires, régulateurs — que l'organisation respecte les exigences applicables, réduisant les risques juridiques et de réputation.

2. Référentiels et Exigences de Contrôle Régulier

Les référentiels de sécurité qui structurent les audits sont nombreux et varient selon le secteur d'activité, la taille de l'organisation et la nature des données traitées. Le tableau suivant présente les principaux référentiels applicables en France et en Europe, avec leurs exigences spécifiques en matière de contrôles réguliers :

Référentiel	Type	Secteurs concernés	Principales exigences en lien avec l'audit technique
ISO 27001:2022	Norme internationale	Tous secteurs	Audit interne annuel, revue de direction, contrôle des actifs, gestion des vulnérabilités, journalisation
NIS2 (Directive UE 2022/2555)	Réglementation UE	Entités essentielles et importantes	Évaluation des risques, contrôle des accès, tests de sécurité réguliers, notification d'incident
RGPD (Règlement UE 2016/679)	Réglementation UE	Toute organisation traitant des données personnelles	Analyse d'impact (AIPD), sécurité des traitements, contrôle des accès, traçabilité
PCI-DSS v4.0	Standard industrie	Organisations traitant des données de paiement	Scan de vulnérabilités trimestriel, test d'intrusion annuel, audit de configuration, segmentation réseau
CIS Controls v8	Référentiel de bonnes pratiques	Tous secteurs	18 contrôles prioritaires couvrant inventaire, configuration, gestion des accès, logs, tests
DORA (Règlement UE 2022/2554)	Réglementation UE	Secteur financier	Tests de résilience ICT, TLPT (Threat Led Penetration Testing), audit des tiers
HDS (Hébergeur de Données de Santé)	Certification française	Hébergeurs de données de santé	Audit de certification annuel, contrôle des accès, traçabilité, plan de continuité testé

Ces référentiels ne sont pas exclusifs : une organisation peut être simultanément soumise à ISO 27001, NIS2 et RGPD, avec des exigences qui se recoupent partiellement. L'enjeu est de concevoir un programme d'audit qui réponde à l'ensemble de ces exigences de manière cohérente et efficiente, en évitant les redondances tout en garantissant une couverture complète.

3. Les Différents Types d'Audits Techniques

Les audits de sécurité se déclinent en plusieurs types, chacun ciblant une dimension spécifique du système d'information et utilisant des méthodes différentes. Le tableau suivant présente les principaux types d'audits rencontrés en pratique :

Type d'audit	Objectif	Méthode principale	Livrables typiques
--------------	----------	--------------------	--------------------

Audit de conformité	Vérifier le respect d'un référentiel (ISO, NIS2, PCI-DSS)	Entretiens, revue documentaire, checklist	Rapport d'écarts, plan d'action correctif
Audit de configuration	Contrôler le durcissement des systèmes et équipements	CIS Benchmark, scripts automatisés, revue manuelle	Rapport de conformité par système, score CIS
Scan de vulnérabilités	Identifier les failles techniques exploitables	Outils automatisés (Nessus, OpenVAS, Qualys)	Rapport de vulnérabilités classé par criticité CVSS
Test d'intrusion (Pentest)	Vérifier l'exploitabilité réelle des vulnérabilités	Exploitation manuelle et automatisée, scénarios d'attaque	Rapport de pentest avec preuves d'exploitation et recommandations
Audit des droits d'accès	Contrôler la cohérence des privilèges accordés	Revue des comptes AD, IAM, bases de données	Matrice des droits, liste des comptes à supprimer ou corriger
Audit des journaux (log review)	Vérifier la complétude et la cohérence des logs de sécurité	Analyse des logs SIEM, vérification des sources	Rapport de couverture des logs, alertes non détectées identifiées

Ces types d'audits sont complémentaires et doivent être articulés dans un programme cohérent. Un scan de vulnérabilités automatisé détecte rapidement un grand nombre de failles techniques mais ne vérifie pas leur exploitabilité réelle dans le contexte spécifique de l'organisation. Un test d'intrusion valide l'exploitabilité mais couvre un périmètre plus restreint en raison du temps et du coût impliqués. Un audit de conformité ISO vérifie les processus organisationnels mais ne teste pas les configurations techniques en profondeur. La combinaison de ces approches est ce qui donne une vision complète et fiable du niveau de sécurité réel.

Chapitre 2 : Planification du Programme d'Audit

1. Construction d'un Programme d'Audit Annuel

Un programme d'audit annuel est le document qui planifie l'ensemble des contrôles de sécurité à réaliser sur une année, en couvrant les différentes dimensions du SI et en répondant aux exigences réglementaires applicables. Il définit pour chaque contrôle : la période de réalisation, le type d'audit, le périmètre concerné, le responsable de sa conduite et le référentiel auquel il se rattache.

Le tableau suivant présente un exemple de programme d'audit annuel pour une organisation de taille intermédiaire, structuré sur l'ensemble de l'année calendaire :

Période	Type de contrôle	Périmètre	Responsable	Référentiel
---------	------------------	-----------	-------------	-------------

Janvier	Scan de vulnérabilités externe	Tous services exposés en DMZ et Internet	RSSI / Prestataire	PCI-DSS, NIS2
Février	Audit de configuration Windows Server	Contrôleurs de domaine, serveurs RDS, Exchange	Équipe sécurité	CIS Benchmark Windows
Mars	Audit des droits d'accès AD	Comptes utilisateurs, groupes à privilèges, comptes de service	RSSI + DSI	ISO 27001, RGPD
Avril	Scan de vulnérabilités interne	Ensemble du réseau LAN et zone serveurs	Équipe sécurité	CIS Controls, ISO 27001
Juin	Test d'intrusion externe	Périmètre exposé (DMZ, VPN, applications web)	Prestataire agréé	PCI-DSS, DORA TLPT
Septembre	Audit de conformité ISO 27001	Ensemble du SMSI	Auditeur interne / externe	ISO 27001:2022
Novembre	Audit de configuration Linux et pare-feu	Serveurs Linux, FortiGate, switches Cisco	Équipe sécurité	CIS Benchmark Linux / Network
Décembre	Revue annuelle des politiques et plans de sécurité	PSSI, PRI, Plan de continuité, règles SIEM	RSSI + Direction	ISO 27001, NIS2

Ce programme couvre les principales dimensions de la sécurité technique (vulnérabilités, configurations, droits d'accès, journalisation) et organisationnelle (conformité ISO, revue des politiques). Il respecte les exigences de fréquence imposées par les référentiels applicables — scan trimestriel pour PCI-DSS, audit annuel pour ISO 27001 — et distribue les contrôles sur l'année pour éviter les surcharges de l'équipe sécurité. Les contrôles les plus critiques (scan de vulnérabilités externe, test d'intrusion) sont répartis sur des périodes distinctes pour couvrir l'évolution du SI dans le temps.

2. Périmètre et Lettre de Mission

Avant tout audit, la définition précise du périmètre est une étape indispensable. Un périmètre mal défini conduit soit à un audit trop large (qui ne peut pas être conduit avec la profondeur nécessaire dans le temps imparti), soit à un audit trop restreint (qui laisse des zones d'ombre et donne une fausse impression de complétude). La définition du périmètre répond à plusieurs questions : quels systèmes, applications ou processus sont inclus ? Quelles zones réseau sont concernées ? Quels référentiels s'appliquent ? Quelles informations peuvent être consultées par l'auditeur ?

La lettre de mission (ou ordre de mission) est le document contractuel qui formalise la relation entre l'auditeur et l'entité auditée. Elle précise le périmètre exact, les objectifs de l'audit, la période de réalisation, les modalités d'accès aux systèmes et aux informations, la liste des contacts dans l'entité auditée, les règles de confidentialité applicables aux informations collectées, et le format attendu du livrable final. Pour les audits techniques impliquant des tests actifs (scans, tests d'intrusion), la lettre de mission inclut une clause d'autorisation explicite listant les adresses IP ou plages réseau pouvant être scannées — un

document indispensable pour protéger l'auditeur juridiquement et garantir que l'équipe IT ne bloque pas les tests.

3. Ressources et Compétences Requises

La conduite d'un programme d'audit complet requiert des compétences variées qui ne sont pas toujours réunies dans une seule équipe. L'audit de conformité ISO ou réglementaire exige une connaissance approfondie des référentiels applicables et des techniques d'entretien et de revue documentaire. L'audit de configuration technique nécessite une maîtrise des systèmes audités (Windows Server, Linux, équipements réseau Cisco/Fortinet) et des outils d'analyse associés. Le test d'intrusion requiert des compétences offensives spécialisées — exploitation de vulnérabilités, post-exploitation, contournement des défenses — qui justifient généralement le recours à un prestataire externe agréé.

Le recours à des auditeurs ou testeurs externes est parfois obligatoire : PCI-DSS impose que les tests d'intrusion soient réalisés par des QSA (Qualified Security Assessors) ou des équipes internes indépendantes du système audité. DORA impose que les TLPT soient réalisés par des « threat intelligence providers » accrédités. ISO 27001 distingue l'audit interne (réalisable en interne avec une équipe formée) de la certification (qui requiert un organisme de certification accrédité comme LRQA, Bureau Veritas, ou SGS).

Chapitre 3 : Méthodologie d'Audit Technique

1. Les Six Phases d'un Audit Technique

Un audit technique rigoureux suit une méthodologie structurée en six phases, garantissant la qualité et la reproductibilité des résultats. Le tableau suivant détaille ces phases, leurs activités, les outils associés et les livrables produits :

Phase	Activités	Outils / Méthodes	Livrables
1. Préparation	Définition du périmètre, revue documentaire préalable, préparation des checklists, coordination avec les équipes	Référentiels (CIS, ISO), documentations existantes, entretiens préliminaires	Lettre de mission, plan d'audit détaillé, checklists adaptées au contexte
2. Collecte	Tests techniques, entretiens, analyse des configurations, extraction des logs, scan d'inventaire	Nmap, Nessus, OpenVAS, scripts d'audit (PowerShell, Bash), CIS-CAT Pro	Données brutes : fichiers de configuration, extraits de logs, résultats de scan
3. Analyse	Qualification des écarts, évaluation de la criticité, croisement	Grille de criticité (CVSS, impact métier), référentiels de	Tableau d'écarts brut, classification provisoire des constats

	avec les référentiels, hiérarchisation	contrôles, jugement d'auditeur	
4. Restitution	Présentation des constats à l'équipe audité, validation factuelle, collecte des éléments de réponse	Réunion de clôture, échanges contradictoires, prise en compte des rectifications factuelles	Procès-verbal de restitution, écarts validés contradictoirement
5. Rapport final	Rédaction du rapport structuré, plan d'action, recommandations hiérarchisées, synthèse exécutive	Template de rapport, grille de priorisation, référence aux bonnes pratiques	Rapport d'audit final, plan d'action correctif avec responsables et délais
6. Suivi	Vérification de la mise en œuvre des actions correctives dans les délais fixés, re-test si nécessaire	Tableau de bord de suivi, re-tests ciblés, entretiens de suivi	Rapport de clôture du plan d'action, attestation de conformité si applicable

2. Phase de Préparation — Clé de la Qualité

La qualité d'un audit se joue pour une large part dans la phase de préparation, souvent sous-estimée. Une préparation insuffisante conduit à des collectes incomplètes, des analyses superficielles et des rapports peu exploitables. La préparation comprend plusieurs activités indispensables. La revue documentaire préalable consiste à analyser les documents de sécurité existants avant de commencer les tests techniques : politique de sécurité, résultats d'audits précédents, cartographie du SI, registre des actifs, procédures de gestion des vulnérabilités. Cette revue permet d'identifier les zones d'attention prioritaires et d'adapter les checklists au contexte spécifique de l'organisation.

La préparation des checklists est l'adaptation des référentiels génériques (CIS Benchmark, ISO 27001) aux spécificités du périmètre audité. Un audit de serveurs Windows Server 2022 utilisera les contrôles CIS Benchmark Windows Server 2022, filtrés selon le niveau d'implémentation cible (IG1, IG2 ou IG3 dans la terminologie CIS). Un audit d'un pare-feu FortiGate utilisera le CIS Benchmark FortiOS ou les recommandations du guide de durcissement Fortinet. Cette adaptation garantit que les contrôles testés sont pertinents pour les technologies effectivement déployées, évitant les constats sans valeur sur des fonctionnalités non utilisées.

3. Techniques de Collecte — Entretiens et Revue Documentaire

L'entretien est une technique de collecte irremplaçable pour les dimensions organisationnelles et procédurales de l'audit. Il permet de vérifier que les processus formalisés dans les documents sont effectivement compris et appliqués par les équipes, de collecter des informations non documentées (pratiques informelles, exceptions non tracées, connaissances tacites des équipes), et de contextualiser les constats techniques (un écart de configuration peut avoir une justification légitime que l'outil automatisé ne peut pas détecter). Les entretiens doivent être conduits avec méthode : questions ouvertes pour permettre des réponses libres, questions de vérification pour confronter les déclarations aux preuves, prise de notes détaillées horodatées.

La revue documentaire porte sur l'ensemble des documents de sécurité applicables : la PSSI (Politique de Sécurité du Système d'Information) et ses documents dérivés, les procédures d'exploitation sécurisée (PES), le plan de reprise d'activité (PRA) et le plan de continuité d'activité (PCA), les contrats avec les prestataires (clauses de sécurité), les rapports d'audits et d'incidents précédents, les tickets de gestion des vulnérabilités et des changements. Chaque document est évalué selon deux dimensions : son existence (le document existe-t-il ?) et sa pertinence (est-il à jour, applicable et connu des équipes concernées ?).

4. Qualification des Écarts et Évaluation de la Criticité

Tous les écarts identifiés lors d'un audit n'ont pas la même importance. Leur qualification selon un niveau de criticité est essentielle pour prioriser les efforts correctifs et communiquer efficacement sur les risques. La criticité d'un écart est évaluée en croisant deux dimensions : la probabilité d'exploitation (un service exposé sur Internet avec une vulnérabilité critique est beaucoup plus probable d'être exploité qu'une mauvaise configuration sur un système interne non exposé) et l'impact potentiel (la compromission d'un contrôleur de domaine Active Directory a un impact incomparablement supérieur à celle d'un poste de travail isolé).

Pour les vulnérabilités techniques, le score CVSS (Common Vulnerability Scoring System) fournit une base standardisée de qualification. Un score CVSS supérieur à 9 (critique) justifie une correction dans les 72 heures. Un score entre 7 et 9 (élevé) doit être corrigé dans les 30 jours. Un score entre 4 et 7 (modéré) peut être planifié dans les 90 jours. Un score inférieur à 4 (faible ou informationnel) peut être inclus dans le backlog de sécurité sans délai imposé, tout en étant documenté. Pour les écarts organisationnels ou procéduraux, la criticité est évaluée par le jugement d'auditeur en combinant l'impact sur la confidentialité, l'intégrité et la disponibilité avec la vraisemblance d'exploitation dans le contexte spécifique de l'organisation.

Chapitre 4 : Audit de Configuration et CIS Benchmarks

1. Les CIS Benchmarks — Référentiel de Configuration Sécurisée

Le Center for Internet Security (CIS) publie des guides de configuration sécurisée — les CIS Benchmarks — pour la quasi-totalité des systèmes d'exploitation, applications et équipements réseau utilisés en entreprise. Ces guides, développés en collaboration avec la communauté internationale d'experts en sécurité, définissent des configurations de référence testées et validées qui réduisent significativement la surface d'attaque des systèmes. Ils sont disponibles gratuitement sur le site du CIS et constituent le référentiel de durcissement le plus adopté au monde.

Chaque CIS Benchmark est structuré selon deux niveaux. Le Niveau 1 regroupe les recommandations fondamentales applicables à tous les systèmes, qui n'impactent pas les fonctionnalités normales et peuvent être déployées sans risque sur la majorité des environnements. Le Niveau 2 contient des recommandations plus restrictives, adaptées aux

environnements à haute sécurité, qui peuvent affecter certaines fonctionnalités ou nécessiter des tests approfondis avant déploiement. Pour chaque recommandation, le benchmark précise le paramètre à configurer, la valeur attendue, la procédure de vérification (audit) et la procédure de correction (remediation), facilitant l'automatisation des contrôles.

2. Audit de Configuration Windows Server

L'audit de configuration Windows Server s'appuie sur le CIS Benchmark Windows Server correspondant à la version déployée (2019, 2022). Les contrôles couvrent plusieurs domaines fondamentaux. La gestion des comptes et des mots de passe vérifie les paramètres de la politique de mots de passe (longueur minimale, complexité, durée de validité, historique), l'état des comptes par défaut (Administrator et Guest), et la configuration de l'écran de veille avec verrouillage automatique. La configuration des services contrôle que seuls les services nécessaires sont actifs (le principe du moindre service), éliminant les vecteurs d'attaque potentiels liés aux services non utilisés.

La configuration du pare-feu Windows vérifie que le pare-feu hôte est actif sur tous les profils (Domain, Private, Public) et que les règles entrantes sont aussi restrictives que possible. Les paramètres d'audit vérifient que les événements de sécurité critiques (ouvertures de session, accès aux objets, gestion des comptes) sont journalisés avec une rétention suffisante. La configuration du registre contrôle des paramètres de sécurité spécifiques : désactivation de NTLMv1 (protocole d'authentification obsolète et vulnérable), activation de la signature SMB (pour prévenir les attaques man-in-the-middle sur les partages réseau), désactivation de la délégation Kerberos non contrainte. Ces vérifications peuvent être réalisées manuellement via des scripts PowerShell ou automatiquement avec l'outil CIS-CAT Pro.

3. Audit de Configuration Linux

L'audit de configuration Linux s'appuie sur le CIS Benchmark de la distribution concernée (Ubuntu, Debian, RHEL, CentOS). Les contrôles prioritaires incluent la vérification de la configuration du système de fichiers (montage en noexec, nosuid, nodev des partitions non système), la configuration des services réseau actifs (vérification via `ss -tlnp` ou `netstat`, désactivation des services non utilisés comme `rpcbind`, `cups`, `avahi`), et la configuration SSH (désactivation de l'authentification par mot de passe en faveur des clés, interdiction de la connexion root directe, limitation des utilisateurs autorisés à se connecter via SSH).

La gestion des utilisateurs et des droits d'accès est un domaine critique : vérification de l'absence de comptes sans mot de passe, des comptes avec UID 0 autres que root (comptes avec droits superutilisateur), de la configuration sudo (restriction des commandes autorisées par utilisateur, journalisation de toutes les commandes sudo). Les scripts d'audit Bash, s'appuyant sur les commandes `cat`, `grep`, `awk` et `ss`, permettent d'automatiser la majorité de ces vérifications et de produire un rapport de conformité en quelques minutes sur chaque serveur.

4. Audit de Configuration des Équipements Réseau

Les équipements réseau — pare-feu, switches, routeurs — sont des cibles de choix pour les attaquants car leur compromission peut affecter l'ensemble du trafic réseau de l'organisation. Leur audit de configuration vérifie le respect des bonnes pratiques de

durcissement spécifiques à chaque constructeur. Sur un pare-feu Fortinet FortiGate, les contrôles prioritaires incluent la désactivation des interfaces d'administration (HTTPS, SSH) sur les interfaces WAN exposées, la restriction de l'accès à l'interface d'administration aux seules adresses IP du réseau de management, la désactivation du protocole HTTP (au profit de HTTPS uniquement), la vérification de la robustesse du mot de passe administrateur et de l'activation du MFA sur le compte admin.

Sur les switches Cisco, l'audit vérifie la désactivation de CDP (Cisco Discovery Protocol) sur les interfaces non trunk, l'activation du port security pour limiter le nombre d'adresses MAC autorisées par port, la désactivation des VLANs non utilisés, la configuration du protocole STP (Spanning Tree Protocol) avec BPDU Guard activé sur les ports d'accès pour prévenir les attaques STP. Ces vérifications s'effectuent via la connexion SSH aux équipements et l'analyse des sorties des commandes show running-config, complétées par des scripts d'audit automatisés (Nornir, Ansible) pour les grands parcs réseau.

Chapitre 5 : Scans de Vulnérabilités et Audits d'Accès

1. Méthodologie du Scan de Vulnérabilités

Le scan de vulnérabilités est un processus automatisé qui interroge les systèmes cibles pour identifier les vulnérabilités connues : services exposés sur des versions logicielles comportant des failles référencées dans les bases CVE, configurations permissives permettant l'accès non authentifié, protocoles obsolètes et vulnérables, certificats SSL expirés ou faibles. Les scanners de vulnérabilités maintiennent des bases de signatures régulièrement mises à jour et comparent l'état des systèmes scannés à ces signatures pour produire un rapport de vulnérabilités classé par niveau de criticité.

La préparation d'un scan de vulnérabilités requiert plusieurs décisions préalables. Le mode de scan — authentifié ou non authentifié — détermine la profondeur de l'analyse. Un scan non authentifié (unauthenticated scan) simule la perspective d'un attaquant sans accès préalable : il est rapide mais détecte uniquement les vulnérabilités exposées à l'extérieur. Un scan authentifié (credentialed scan) utilise des identifiants fournis pour accéder au système et analyser la configuration interne, les versions de logiciels installés et les politiques locales — il détecte bien plus de vulnérabilités mais requiert des comptes dédiés avec des droits de lecture suffisants. En production, les deux modes sont complémentaires : le scan non authentifié simule l'attaquant, le scan authentifié donne la vision complète.

2. Outils de Scan — Nessus et OpenVAS

Nessus, développé par Tenable, est le scanner de vulnérabilités commercial le plus déployé dans le monde de l'entreprise. Sa version Nessus Essentials est gratuite pour un usage limité (jusqu'à 16 adresses IP), tandis que Nessus Professional et Tenable.io offrent des fonctionnalités avancées pour les grandes infrastructures. Nessus dispose d'une base de plus de 170 000 plugins de détection, couvrant l'ensemble des systèmes d'exploitation, applications et équipements réseau courants. Son interface web intuitive permet de

configurer des politiques de scan, planifier des scans récurrents et exporter les rapports dans de nombreux formats (PDF, CSV, XML).

OpenVAS (Open Vulnerability Assessment System), maintenu par Greenbone Networks, est l'alternative open source de référence. Son moteur GVM (Greenbone Vulnerability Management) intègre une base de NVT (Network Vulnerability Tests) régulièrement mise à jour et un tableau de bord web complet. Il est particulièrement adapté aux organisations souhaitant déployer une solution de scan sans coût de licence, avec la contrepartie d'une installation et d'une maintenance plus complexes qu'une solution commerciale. Ces deux outils supportent les scans authentifiés via SSH pour Linux, WMI/SMB pour Windows et SNMP pour les équipements réseau, ainsi que les scans non authentifiés pour tous les hôtes réseau.

3. Interprétation et Priorisation des Résultats

Un scan de vulnérabilités produit fréquemment des centaines, voire des milliers de résultats sur un SI de taille moyenne. La capacité à prioriser efficacement ces résultats pour concentrer les efforts correctifs sur les risques les plus critiques est une compétence essentielle. La priorisation ne se limite pas au score CVSS : elle doit intégrer le contexte de l'organisation. Une vulnérabilité CVSS 9 sur un système de développement isolé présente un risque moindre qu'une vulnérabilité CVSS 7 sur un serveur de base de données contenant des données personnelles et accessible depuis Internet.

La notion de vulnérabilité exploitable est cruciale : certaines vulnérabilités référencées dans les CVE ont un exploit public disponible (signalé dans les bases de données comme Exploit-DB ou Metasploit Framework), rendant leur exploitation accessible à un attaquant sans compétences spécialisées. Ces vulnérabilités avec exploit public doivent être priorisées au-dessus des vulnérabilités de score CVSS similaire mais sans exploitation publique connue. Le croisement du score CVSS, de la disponibilité d'un exploit public, de l'exposition du système (Internet-facing ou interne) et de la criticité de l'actif affecté est la méthode de priorisation la plus robuste, souvent formalisée dans un score EPSS (Exploit Prediction Scoring System) complémentaire au CVSS.

4. Audit des Droits d'Accès Active Directory

L'Active Directory (AD) est le composant le plus critique de la majorité des SI d'entreprise Windows : il contrôle l'authentification et les autorisations de l'ensemble des utilisateurs et des machines du domaine. Sa compromission donne à un attaquant un contrôle total sur l'organisation. L'audit des droits d'accès AD est donc une priorité dans tout programme d'audit de sécurité et doit couvrir plusieurs périmètres.

La revue des comptes à privilèges identifie l'ensemble des membres des groupes Domain Admins, Enterprise Admins, Schema Admins, Administrators et Backup Operators. Ces groupes doivent être aussi restreints que possible — un principe de moindre privilège appliqué au niveau du domaine. L'outil BloodHound, originellement développé pour les tests d'intrusion, est aujourd'hui utilisé par les équipes sécurité défensives pour cartographier les chemins d'attaque potentiels dans l'AD : il identifie les utilisateurs ordinaires qui peuvent atteindre Domain Admins via des relations de délégation ou d'appartenance à des groupes intermédiaires, souvent sans que les administrateurs en soient conscients. L'outil PingCastle produit un score de sécurité de l'AD et un rapport détaillé des configurations problématiques.

(délégation Kerberos non contrainte, comptes sans pré-authentification Kerberos, comptes AdminSDHolder mal configurés).

Chapitre 6 : Documentation des Écarts et Plan d'Action

1. Structure d'un Constat d'Écart

La qualité d'un rapport d'audit se mesure avant tout à la qualité de ses constats. Un constat bien rédigé doit être factuel (basé sur des preuves observées, non sur des suppositions), précis (décrivant exactement ce qui a été observé, sur quel système, à quelle date), référencé (relié au contrôle du référentiel applicable qui n'est pas respecté), et exploitable (accompagné d'une recommandation concrète permettant à l'équipe de corriger l'écart sans ambiguïté).

La structure minimale d'un constat comprend un identifiant unique (EC-01, EC-02, etc.) permettant le suivi dans le plan d'action, une description précise de l'écart observé avec la preuve associée (capture d'écran, extrait de configuration, résultat de commande), le niveau de criticité évalué selon les critères définis (Critique, Élevé, Modéré, Faible), la référence au contrôle du référentiel non respecté (CIS 5.2, ISO A.9.4, NIS2 Art.21), une recommandation de remédiation concrète et réalisable dans le contexte de l'organisation, et un délai cible de correction cohérent avec le niveau de criticité.

2. Tableau de Documentation des Écarts

Le tableau des écarts est le document central du rapport d'audit. Il synthétise l'ensemble des constats de manière structurée et facilement exploitable pour la construction du plan d'action. Le tableau suivant présente un exemple de documentation d'écarts issus d'un audit technique couvrant plusieurs domaines :

N °	Contrôle audité	Constat / Écart	Critic ité	Réf.	Recommandation	Délai cible
EC-001	Gestion des mots de passe — politique de complexité	12 comptes utilisateurs avec mots de passe n'ayant pas expiré depuis plus de 180 jours	Élevé	CIS 5.2 / ISO A.9.4	Activer la politique d'expiration des mots de passe (90 jours max) et forcer la réinitialisation immédiate des 12 comptes identifiés	J+15
EC-002	Patch management — correctifs OS	3 serveurs Windows Server 2019 présentent des mises à jour critiques non	Critique	CIS 7.3 / NIS2 Art.21	Déployer les correctifs manquants via WSUS dans les 72 heures pour les CVE critiques, mettre en place un processus de déploiement sous 30	J+3 (critique) / J+30

		appliquées depuis plus de 60 jours (dont CVE-2023-44487, CVSS 7.5)			jours pour les correctifs élevés	
E C - 0 3	Comptes administrateurs locaux	18 postes de travail possèdent un compte administrateur local actif avec le mot de passe par défaut constructeur	Critique	CIS 4.7 / ISO A.9.2	Déployer LAPS (Local Administrator Password Solution) sur l'ensemble du parc pour gérer les mots de passe administrateurs locaux de manière aléatoire et individuelle	J+30
E C - 0 4	Journalisation — couverture des sources	4 serveurs Linux de production ne transmettent pas leurs logs vers le SIEM centralisé	Modéré	CIS 8.2 / NIS2 Art.21	Déployer l'agent Wazuh sur les 4 serveurs concernés et vérifier l'ingestion dans les 7 jours	J+7
E C - 0 5	Chiffrement des sauvegardes	Les sauvegardes journalières des bases de données sont stockées en clair sur le serveur de backup NAS	Élevé	CIS 11.3 / RGP D Art.32	Activer le chiffrement AES-256 des fichiers de sauvegarde au niveau de la solution de backup (Veeam) et vérifier que la clé de chiffrement est stockée séparément	J+20

3. Construction du Plan d'Action Correctif

Le plan d'action correctif (PAC) est le document opérationnel qui traduit les constats du rapport d'audit en actions concrètes, assignées à des responsables identifiés avec des délais précis et des critères de clôture vérifiables. C'est le pont entre le diagnostic (le rapport d'audit) et la guérison (la correction effective des vulnérabilités). Un PAC sans responsables désignés est un vœu pieux ; un PAC sans délais est une liste d'intentions ; un PAC sans critères de clôture est invérifiable.

La hiérarchisation des actions dans le PAC suit la criticité des écarts : les écarts critiques (score CVSS supérieur à 9 ou impact systémique majeur) doivent être traités en premier, dans les 72 heures à une semaine selon leur nature. Les écarts élevés sont planifiés dans le mois suivant l'audit. Les écarts modérés peuvent être planifiés dans les 90 jours. Les écarts faibles entrent dans le backlog de sécurité et sont traités lors des maintenances planifiées. Cette hiérarchisation doit être validée par le RSSI et communiquée à la direction pour garantir l'allocation des ressources nécessaires à la correction des points les plus critiques.

4. La Revue Contradictoire — Garantie de Qualité

Avant la finalisation et la diffusion du rapport d'audit, une revue contradictoire doit être organisée avec l'équipe auditée. Cette réunion de clôture présente l'ensemble des constats et permet à l'équipe de faire valoir ses observations : correction d'erreurs factuelles (un écart basé sur une mauvaise interprétation d'une configuration), apport de contexte (une exception documentée qui justifie un écart apparent), ou indication que la correction est déjà en cours (et peut donc bénéficier d'un délai plus court dans le PAC).

La revue contradictoire ne doit pas être une négociation des conclusions : si un écart est factuel et documenté, il reste dans le rapport, même si l'équipe auditée conteste son niveau de criticité. En revanche, les erreurs factuelles doivent absolument être corrigées avant publication — un rapport contenant des constats erronés perd toute crédibilité et peut créer des tensions inutiles entre l'équipe d'audit et les équipes opérationnelles. Le procès-verbal de la réunion contradictoire est annexé au rapport final comme preuve que ce processus de validation a été conduit.

Chapitre 7 : Rapport d'Audit et Pilotage de la Conformité

1. Structure d'un Rapport d'Audit Complet

Le rapport d'audit est le livrable principal de toute mission d'audit. Sa qualité détermine l'utilité de l'audit : un rapport trop technique, illisible par la direction, n'aboutira pas aux décisions nécessaires ; un rapport trop synthétique, sans détails techniques suffisants, ne permettra pas aux équipes IT de corriger les écarts identifiés. Un bon rapport d'audit s'adresse simultanément à plusieurs audiences, ce qui nécessite de structurer son contenu en couches d'information de profondeur croissante.

La synthèse exécutive est la première section du rapport, conçue pour une lecture de 5 minutes par le RSSI ou la direction générale. Elle présente le contexte et les objectifs de l'audit, le périmètre couvert, une évaluation globale du niveau de conformité (par exemple, sous forme d'un score ou d'une appréciation qualitative), le nombre et la distribution des écarts par niveau de criticité, les trois ou quatre constats les plus significatifs, et les priorités d'action recommandées. Cette synthèse ne contient aucun détail technique — elle communique les risques en termes de gouvernance et d'impact business.

Le corps du rapport contient le détail de chaque constat avec ses preuves, la description complète de la méthode utilisée pour chaque contrôle, le tableau des écarts complet avec les références aux référentiels, et le plan d'action correctif détaillé. Les annexes regroupent les données brutes collectées (résultats de scans, extraits de configuration, captures d'écran), la liste des personnes rencontrées en entretien, le procès-verbal de la revue contradictoire et les documents collectés pendant l'audit.

2. Indicateurs de Pilotage de la Conformité

Au-delà du rapport d'audit ponctuel, une organisation mature met en place des indicateurs de conformité suivis en continu, permettant de mesurer l'évolution du niveau de sécurité

dans le temps et de piloter la correction des écarts. Ces indicateurs alimentent le tableau de bord RSSI et le reporting mensuel à la direction. Le taux de conformité global mesure le pourcentage de contrôles du référentiel applicable satisfaits lors du dernier audit : un taux de 85 % signifie que 15 % des contrôles présentent des écarts. Suivi d'un audit à l'autre, cet indicateur traduit l'évolution du niveau de conformité et l'efficacité du programme de correction.

Le taux de clôture du plan d'action mesure le pourcentage d'actions correctives réalisées dans les délais définis. Un taux élevé signifie que les engagements pris sont tenus ; un taux faible signifie que les ressources allouées à la correction sont insuffisantes ou que les délais ont été définis de manière irréaliste. Le délai moyen de correction par niveau de criticité mesure combien de temps s'écoule en pratique entre l'identification d'un écart et sa correction, permettant d'évaluer la capacité opérationnelle de l'organisation à répondre aux constats d'audit.

3. Gestion des Vulnérabilités Résiduelles

Toutes les vulnérabilités identifiées lors d'un audit ne peuvent pas être corrigées immédiatement. Des contraintes techniques (impossibilité de patcher un système legacy sans le casser), économiques (coût de remplacement d'un équipement obsolète supérieur à la valeur de l'actif protégé) ou opérationnelles (impossibilité d'interrompre un service de production pour appliquer un correctif) peuvent empêcher la correction dans les délais théoriques. Dans ce cas, la vulnérabilité doit être documentée comme vulnérabilité résiduelle, avec une acceptation de risque formelle.

L'acceptation de risque est un processus documenté par lequel la direction — et non l'équipe technique — décide formellement d'accepter le risque associé à une vulnérabilité non corrigée, en connaissance de cause. Elle doit préciser la vulnérabilité acceptée, le risque associé en termes d'impact potentiel, les mesures compensatoires mises en place pour réduire la probabilité d'exploitation (surveillance renforcée, restrictions d'accès supplémentaires, segmentation réseau), la durée d'acceptation (une acceptation permanente est rarement justifiée) et le responsable ayant approuvé l'acceptation. Ce processus garantit que les choix de sécurité sont conscients et traçables, et non le résultat d'une inaction non documentée.

Chapitre 8 : Cas Pratique — Programme d'Audit pour une ETI

1. Présentation du Contexte

LogiTech Solutions est une ETI de 280 salariés spécialisée dans le développement de logiciels de gestion industrielle. Elle traite des données personnelles de ses clients dans le cadre de contrats de maintenance SaaS, la rendant soumise au RGPD. Son secteur d'activité la classe comme entité importante au sens de NIS2 depuis la transposition française. Son DSI souhaite lancer un premier programme d'audit structuré suite à la réception d'un questionnaire de sécurité d'un grand client bancaire. L'équipe sécurité se

compose du RSSI (0,5 ETP) et d'un ingénieur sécurité (1 ETP). Le budget annuel alloué au programme d'audit est de 25 000 euros, incluant les prestations externes.

L'infrastructure à auditer comprend : 15 serveurs Linux Ubuntu hébergeant la plateforme SaaS, 5 serveurs Windows Server 2022 (AD, base de données SQL Server, serveur de fichiers), 250 postes de travail Windows 11, un pare-feu Fortinet FortiGate 200F, et une infrastructure cloud AWS (3 comptes, une trentaine d'instances EC2 et services managés). La direction souhaite un premier bilan de conformité dans les 3 mois, suivi d'un programme d'audits réguliers.

2. Phase 1 — Audit Initial de Conformité (Semaines 1 à 4)

L'audit initial vise à produire un état des lieux complet du niveau de sécurité de l'organisation selon les référentiels ISO 27001, CIS Controls v8 et RGPD. La semaine 1 est consacrée à la préparation : revue de la documentation existante (PSSI, procédures, contrats, résultats d'audits antérieurs), entretiens avec le DSI et le RSSI pour comprendre le contexte organisationnel, et adaptation des checklists aux technologies déployées (CIS Benchmark Ubuntu 22.04, Windows Server 2022, FortiOS).

La semaine 2 est dédiée aux tests techniques : scan de vulnérabilités authentifié sur l'ensemble des serveurs Linux et Windows avec Nessus Essentials (16 IP couvertes gratuitement, achat d'une licence Professional pour le reste), audit de configuration automatisé avec CIS-CAT Pro sur 5 serveurs représentatifs de chaque catégorie, audit manuel des règles du FortiGate (export de la configuration via SSH et analyse ligne par ligne), et extraction des données AD pour audit des droits (BloodHound, PingCastle). Les semaines 3 et 4 sont consacrées à l'analyse des résultats, la rédaction des constats et la préparation du rapport.

3. Résultats et Principaux Constats

L'audit initial produit 47 constats répartis comme suit : 6 critiques, 18 élevés, 17 modérés et 6 faibles. Les 6 constats critiques sont : absence de MFA sur l'accès à la console AWS pour 3 comptes IAM administrateurs, 2 serveurs Linux Ubuntu exposant le port 22 (SSH) directement depuis Internet sans restriction IP, un compte de service SQL Server membre du groupe Domain Admins (droits largement excessifs), des snapshots AWS EBS non chiffrées pour 8 instances contenant des données clients, la politique de mots de passe AD n'imposant ni complexité ni expiration (tous les comptes utilisateurs peuvent avoir des mots de passe de 4 caractères), et un certificat TLS du portail client expiré depuis 23 jours (accès toujours fonctionnel en acceptant l'alerte).

Ces 6 constats critiques reçoivent une attention immédiate de la direction lors de la réunion de restitution. Le PDG est particulièrement sensible à l'absence de MFA sur AWS — un accès non autorisé à la console AWS pourrait donner à un attaquant le contrôle total de l'infrastructure cloud en quelques minutes. La correction des 6 constats critiques est lancée avant même la finalisation du rapport : activation du MFA AWS le jour même de la restitution, restriction de l'accès SSH aux IP du réseau VPN, retrait du compte de service du groupe Domain Admins en urgence.

4. Construction du Plan d'Action et Suivi

Le plan d'action correctif couvre les 47 constats avec des délais adaptés à leur criticité. Pour les 6 constats critiques, les actions sont assignées avec un délai de J+7 et une vérification de clôture par l'ingénieur sécurité. Pour les 18 constats élevés, le délai est J+30, avec un point d'avancement hebdomadaire. Pour les 17 constats modérés, le délai est J+90, avec suivi mensuel. Un tableau de bord de suivi est mis en place dans Jira avec une colonne par statut (À faire, En cours, Terminé, Vérifié), permettant au RSSI de suivre l'avancement en temps réel et de produire un reporting mensuel à la direction.

Deux mois après la publication du rapport, le bilan de suivi indique : 6 sur 6 constats critiques clôturés et vérifiés, 14 sur 18 constats élevés clôturés (4 en cours, dont le déploiement LAPS sur l'ensemble du parc, planifié sur 6 semaines), 8 sur 17 constats modérés clôturés. Le taux de clôture global est de 59 % à J+60, en ligne avec les objectifs. Le grand client bancaire, informé de la démarche d'audit et des actions en cours, a transmis une évaluation positive du niveau de maturité sécurité de LogiTech Solutions — l'investissement dans le programme d'audit a directement contribué à sécuriser le contrat commercial.

Synthèse Générale du Module

Ce cours vous a conduit depuis les fondements conceptuels des audits de sécurité jusqu'à la mise en œuvre concrète d'un programme d'audit complet dans un contexte d'entreprise réel, en passant par les référentiels applicables, la méthodologie d'audit en six phases, les techniques de contrôle de configuration et de scan de vulnérabilités, la documentation rigoureuse des écarts et le pilotage du plan d'action correctif.

Trois grandes leçons synthétisent l'ensemble du cours. La première est que l'audit sans suivi n'a aucune valeur. Un rapport d'audit, aussi précis et complet soit-il, ne protège pas l'organisation si les écarts qu'il identifie ne sont pas corrigés. La qualité d'un programme d'audit se mesure autant à la rigueur des contrôles réalisés qu'à l'efficacité du suivi des plans d'action. Un programme qui produit des rapports sans piloter les corrections est une dépense sans retour sur investissement. Le RSSI qui conduit un audit doit se considérer responsable du résultat jusqu'à la clôture du plan d'action, pas seulement jusqu'à la remise du rapport.

La deuxième leçon est que la régularité des contrôles est aussi importante que leur profondeur. Un audit exhaustif réalisé une fois tous les trois ans est moins efficace qu'une combinaison de contrôles légers mensuels, de scans de vulnérabilités trimestriels et d'un audit complet annuel. Les configurations dérivent, les vulnérabilités apparaissent quotidiennement, les droits s'accumulent au fil des années : seule une surveillance continue permet de détecter ces dégradations progressives avant qu'elles ne créent des failles exploitables.

La troisième leçon est que la documentation des écarts est un acte de gouvernance, pas une formalité administrative. Un écart bien documenté, avec sa preuve, sa criticité, sa recommandation et son délai de correction, est une information décisionnelle qui permet à la direction d'allouer les ressources correctement et de mesurer le niveau de risque résiduel. Une organisation qui documente ses écarts et pilote leur correction de manière transparente

démontre une maturité sécurité que les clients, les partenaires et les régulateurs reconnaissent et valorisent — comme l'illustre le cas pratique de ce cours.

Glossaire

Terme	Définition
AIPD	Analyse d'Impact sur la Protection des Données — étude obligatoire sous RGPD pour les traitements susceptibles de présenter un risque élevé pour les droits et libertés des personnes.
Audit interne	Contrôle réalisé par des ressources appartenant à l'organisation auditée, évaluant la conformité aux politiques internes et aux référentiels applicables.
Benchmarking CIS	Ensemble de recommandations de configuration sécurisée publiées par le Center for Internet Security, couvrant les principaux systèmes d'exploitation, applications et équipements réseau.
CIS Controls	Les 18 contrôles de sécurité prioritaires publiés par le Center for Internet Security, structurés en trois groupes d'implémentation (IG1, IG2, IG3) selon la maturité de l'organisation.
Constat d'écart	Observation documentée lors d'un audit identifiant une non-conformité entre la situation observée et l'exigence du référentiel applicable, accompagnée d'une preuve et d'une recommandation.
CVSS	Common Vulnerability Scoring System — score standardisé (0 à 10) évaluant la sévérité d'une vulnérabilité selon son vecteur d'exploitation, sa complexité, ses impacts sur la confidentialité, l'intégrité et la disponibilité.
Durcissement (hardening)	Processus de sécurisation d'un système en réduisant sa surface d'attaque : suppression des services inutiles, application de configurations restrictives, application des correctifs, restriction des droits.
Écart (gap)	Différence mesurée entre l'état observé d'un contrôle de sécurité et l'état attendu selon le référentiel applicable, constituant un risque à traiter par un plan d'action correctif.
LAPS	Local Administrator Password Solution — solution Microsoft gérant automatiquement les mots de passe des comptes administrateurs locaux des postes de travail, en les rendant uniques et aléatoires par machine.
Pentest	Test d'intrusion — évaluation de la sécurité d'un système par simulation d'attaques réelles, réalisée par des experts mandatés pour identifier et exploiter les vulnérabilités dans un cadre contractuel défini.
Plan d'action correctif (PAC)	Document formalisant les actions à mettre en œuvre pour corriger les écarts identifiés lors d'un audit, avec pour chaque action : un responsable désigné, un délai cible et un critère de clôture vérifiable.
Revue contradictoire	Phase de l'audit durant laquelle les constats sont présentés à l'entité auditée pour validation factuelle, permettant de corriger d'éventuelles erreurs d'interprétation avant la publication du rapport final.
SMSI	Système de Management de la Sécurité de l'Information — cadre organisationnel et documentaire structurant la gestion de la sécurité de l'information selon la norme ISO 27001.
Surface d'attaque	Ensemble des points d'entrée potentiels exploitables par un attaquant pour compromettre un système : ports ouverts, services exposés, comptes à privilèges, configurations permissives.
TLPT	Threat-Led Penetration Testing — test d'intrusion avancé guidé par des scénarios de menace réels (threat intelligence), requis par le règlement DORA pour les entités financières critiques.

Vulnérabilité résiduelle

Vulnérabilité connue et documentée dont le risque a été accepté formellement par la direction, en raison de contraintes techniques ou économiques rendant sa correction impossible ou disproportionnée.